

VULNERABILITY MATRIX

Project Title: Security Audit of OWASP Juice Shop

Assessment Type: Web Application Security Assessment

Assessment Environment: Local Laboratory (Docker)

Tools Used: Kali Linux, Nmap, Burp Suite Community Edition, OWASP ZAP

Table 1 Vulnerability Matrix

Finding ID	Vulnerability / Observation	OWASP Category	Risk	Verification Method	Evidence (Figures)	Potential Impact	Recommended Remediation	Current Status
F-01	Content Security Policy (CSP) Header Not Set	A05 – Security Misconfiguration	Medium	OWASP ZAP	Figure 7.1	Absence of a CSP increases the impact of potential Cross-Site Scripting (XSS) attacks by allowing unrestricted execution of browser content.	Configure an appropriate Content-Security-Policy (CSP) header defining trusted content sources.	Open
F-02	Missing Anti-Clickjacking Protection	A05 – Security Misconfiguration	Medium	OWASP ZAP	Figure 7.2	Application pages may be embedded inside malicious websites, enabling clickjacking attacks.	Configure X-Frame-Options or implement Content-Security-Policy: frame-ancestors .	Open
F-03	Authentication Mechanism Verified	A07 – Identification and Authentication Failures	Informational	Burp Suite	Figures 7.3 & 7.4	Authentication successfully rejected invalid credentials and did not disclose sensitive account information. No	Continue using generic authentication failure messages and periodically review authentication controls and password policies.	Verified

Finding ID	Vulnerability / Observation	OWASP Category	Risk	Verification Method	Evidence (Figures)	Potential Impact	Recommended Remediation	Current Status
						authentication bypass was identified.		
F-04	Input Validation Assessment	A03 – Injection	Informational	Burp Suite	Figures 7.5 & 7.6	Tested SQL Injection and Cross-Site Scripting payloads did not execute or produce abnormal application behaviour during assessment.	Continue implementing server-side validation, output encoding, and parameterized database queries.	Verified
F-05	Session Management Verification	A01 – Broken Access Control	Low	Burp Suite	Figure 7.7	User session was successfully terminated after logout, preventing unauthorized access to protected resources.	Continue secure session management practices, invalidate authentication tokens after logout, and periodically review session timeout policies.	Verified

Table 2 Risk Distribution

Risk Level	Number of Findings	Percentage
High	0	0%
Medium	2	40%
Low	1	20%
Informational	2	40%
Total	5	100%

Table 3 OWASP Top 10 Coverage

OWASP Top 10 (2021) Category	Assessment Status
A01 – Broken Access Control	Partially Assessed
A02 – Cryptographic Failures	Partially Assessed
A03 – Injection	Assessed
A04 – Insecure Design	Not Assessed
A05 – Security Misconfiguration	Assessed
A06 – Vulnerable and Outdated Components	Not Assessed
A07 – Identification and Authentication Failures	Assessed
A08 – Software and Data Integrity Failures	Not Assessed
A09 – Security Logging and Monitoring Failures	Not Assessed
A10 – Server-Side Request Forgery (SSRF)	Not Assessed

Table 4 Overall Assessment Summary

Assessment Item	Result
Total Findings Identified	5
Critical Findings	0
High-Risk Findings	0
Medium-Risk Findings	2

Assessment Item	Result
Low-Risk Findings	1
Informational Findings	2
Manual Testing Tools	Burp Suite Community Edition, Nmap
Automated Testing Tool	OWASP ZAP
Overall Security Assessment	Moderate Security Posture – Configuration improvements recommended

Matrix Summary

The security assessment identified **five documented findings**, comprising **two Medium-risk configuration issues**, **one Low-risk observation**, and **two Informational findings**. Manual testing confirmed that authentication, session management, and input validation functioned as expected for the scenarios tested. The automated OWASP ZAP scan primarily identified configuration-related observations, particularly missing browser security headers. No Critical or High-risk vulnerabilities were identified during the scope of this assessment. Implementing the recommended remediation measures will improve the application's security posture and align it more closely with OWASP Top 10 (2021) best practices.